DOCUMENTACION DE SISTEMA

RootCause Bitcoin Defense

15 · Riesgos y deuda técnica

Version analizada 0.3.0 · commit acdf4dd · generado el 2026-08-27
Documento 15 de la serie · fuente: docs/system-documentation/15-risks-and-technical-debt.md

Contenido

1 · Escala de clasificación
2 · Resumen
3 · Hallazgos de severidad alta
4 · Hallazgos de severidad media
5 · Hallazgos de severidad baja
6 · Escalabilidad
7 · Observaciones
8 · Lo que este análisis no pudo evaluar
9 · Decisiones que requieren validación humana

Hallazgos de este análisis, clasificados. **Documento informativo: nada de lo aquí listado se ha corregido**, salvo la documentación del propio código.

> **Cómo leerlo.** Un hallazgo aquí no es un defecto que alguien pasó por alto: varios son decisiones conscientes del proyecto, y así se indica. Lo que este documento aporta es tenerlos todos escritos en un sitio, con su evidencia y su prioridad, para que la decisión de aceptarlos siga siendo una decisión y no un olvido.

1 · Escala de clasificación

Severidad	Significado
[FALLO] Alta	Puede causar pérdida de datos, exposición o un diagnóstico incorrecto sobre fondos reales
[ALTA] Media	Degrada la fiabilidad o el mantenimiento; no compromete la seguridad por sí solo
[ATENCION] Baja	Fricción, inconsistencia o deuda menor
[NO COMPROBADO] Observación	No es un defecto; se registra para que la decisión quede explícita
Corregido	Se arregló después de este análisis; la fila conserva el hallazgo original

Prioridad	Criterio
P1	Atender antes del siguiente release
P2	Atender en el próximo ciclo
P3	Cuando toque el módulo
P4	Registrado, sin acción prevista

---

2 · Resumen

Severidad	Abiertos	Corregidos
[FALLO] Alta	3	**1**
[ALTA] Media	8	**1**
[ATENCION] Baja	8	0
[NO COMPROBADO] Observación	4	0
Total	**23**	**2**

> **Corregidos tras este análisis:** R-03 (colecciones no reparadas al inicializar) y R-09 (`mergeIncidents` sin prueba directa). Sus fichas se conservan abajo con el hallazgo original y la corrección aplicada, porque borrarlas dejaría al lector sin saber qué pasó.

Categoría	Hallazgos
Limitaciones del modelo	3
Robustez y datos	7
Cobertura de pruebas	4
Configuración	4
Escalabilidad	3
Cadena de suministro	2
Documentación y coherencia	2

---

3 · Hallazgos de severidad alta

R-01 · El sistema no puede verificar la procedencia que se le declara

Campo	Valor
Severidad	[FALLO] Alta
Prioridad	**P4 — limitación de fondo, no corregible**

Campo	Valor
Impacto	Un dato de procedencia erróneo produce un análisis erróneo sobre fondos reales
Probabilidad	Media. Recordar el firmware con el que se creó una semilla hace años es difícil
Evidencia	`src/services/defense-service.js` → `normalizeSigner` acepta cualquier cadena
Ubicación	Todo el modelo de datos
Recomendación	**Ninguna técnica.** Ya está mitigado por diseño: omitir el dato no lo oculta, lo convierte en `BTC-KEY-002`. Mantener esa asimetría y seguir declarándola en la documentación de usuario

> Es el límite honesto del producto, y el propio repositorio lo declara en `../LIMITACIONES.md`. Se registra aquí porque un auditor debe verlo escrito, no deducirlo.

R-02 · Exponer el puerto invalida el modelo de seguridad completo

Campo	Valor
Severidad	[FALLO] Alta
Prioridad	P4 — decisión de diseño declarada
Impacto	Cualquiera en la red ve el inventario, los saldos y los fabricantes, **y puede modificarlo**: no hay autenticación
Probabilidad	Baja con la configuración por defecto; alta si alguien «lo pone accesible desde el móvil»
Evidencia	Ausencia de autenticación en `src/app.js` y `src/api/router.js`
Mitigación existente	Bind loopback por defecto, `BTC-OPSEC-001` crítico, verificación en cada build
Recomendación	Mantener. Si alguna vez se soportara acceso remoto, **la autenticación tendría que preceder a esa función**, no seguirla

R-03 · `evaluateState` presupone tres arrays que `initialize` no repara

> **CORREGIDO.** `initialize()` repara ahora las seis colecciones del estado, y `test/incident-lifecycle.test.js` lo comprueba con un estado incompleto. La ficha se conserva con el hallazgo original.

Campo	Valor
Severidad	[FALLO] Alta · corregido
Prioridad	**P1** — atendida
Impacto	Un estado sin `wallets`, `observedTransactions` o `privacyEvents` hace lanzar `TypeError` y **el arranque falla**
Probabilidad	Baja hoy: `createEmptyState` siempre los crea. Sube en cuanto exista un estado escrito por otra versión o editado a mano

Campo	Valor
Evidencia	`src/domain/rule-engine.js` → `evaluateState` accede a `state.wallets.flatMap(...)` sin guarda; `defense-service.js` → `initialize` **solo** repara `incidents` y `audit`
Recomendación	Reparar las tres colecciones en `initialize()` igual que se reparan las otras dos, o dar guardas en `evaluateState`. **Cuesta cinco líneas**
Corrección aplicada	`initialize()` recorre `wallets`, `incidents`, `approvals`, `observedTransactions`, `privacyEvents` y `audit`, y repara como array vacío la que no lo sea. Un estado incompleto ya no impide arrancar: arranca vacío, que es lo que describe la situación
Prueba que lo protege	`test/incident-lifecycle.test.js` → *«initialize repara las colecciones que falten en el estado»*. Se comprobó que **falla** con el código anterior

R-04 · No hay comprobación de `schemaVersion` al cargar

Campo	Valor
Severidad	[FALLO] Alta *(latente)*
Prioridad	**P2**
Impacto	Un estado escrito por una versión futura se cargaría sin protestar y podría interpretarse mal
Probabilidad	Nula hoy —solo existe la versión 1—; **cierta en cuanto haya una versión 2**
Evidencia	`decryptJson` verifica `envelope.version`; **nadie verifica `state.schemaVersion`**
Recomendación	Comprobarlo en `initialize()` y fallar de forma explícita ante una versión desconocida. Es más barato ahora que después

---

4 · Hallazgos de severidad media

R-05 · `walletId` sin integridad referencial

Campo	Valor
Severidad	[ALTA] Media · Prioridad P2
Impacto	Un evento puede citar una wallet inexistente. `BTC-TX-001` dispara, `BTC-TX-002` **se salta el evento en silencio**
Evidencia	`observeTransaction` valida la forma de `walletId`, no su existencia; `evaluateCorrelations` hace `continue` si no la encuentra
Recomendación	Validar contra el inventario y devolver `400`, o al menos emitir un hallazgo informativo por evento huérfano en vez de saltarlo

R-06 · `expiresAt` de las aprobaciones no se comprueba nunca

Campo	Valor
Severidad	[ALTA] Media · Prioridad P2

Campo	Valor
Impacto	Una aprobación caducada **sigue considerándose válida** indefinidamente, así que un gasto con ese hash no genera `BTC-TX-001`
Evidencia	`approvePolicyHash` guarda el campo; ninguna regla lo lee
Recomendación	Comparar contra `now` en `evaluateTransaction` y `evaluateCorrelations`. Mientras tanto, **no documentarlo como si funcionara**

R-07 · Buena parte de `config/policies.json` es declarativa

Campo	Valor
Severidad	[ALTA] Media · Prioridad P3
Impacto	Cambiar `blockUnknownFirmware` a `false` no desactiva nada; `highValueThresholdSats` del archivo se ignora frente a la variable de entorno
Evidencia	`evaluate()` solo lee `policies.advisoryMaxAgeDays` —campo que **ni siquiera está en el archivo**— y la etapa 14 lee `humanApprovalRequired`
Recomendación	O aplicarlos, o marcarlos en el propio archivo como declarativos. Un archivo de política que no gobierna es una promesa que alguien acabará creyéndose

R-08 · Asimetría en la anotación de reanálisis

Campo	Valor
Severidad	[ALTA] Media · Prioridad P3
Impacto	`observeTransaction` y `observePrivacyEvent` reevalúan y refunden incidentes **sin escribir la entrada `auto_rescan`**. La traza de auditoría no refleja el reanálisis
Evidencia	`rescanAfterChange` se invoca **solo** desde `addWallet`
Recomendación	Usar `rescanAfterChange` en las tres operaciones, o documentar por qué solo en una

R-09 · `mergeIncidents` no tiene ninguna prueba directa

> **CORREGIDO.** 12 pruebas directas en `test/incident-lifecycle.test.js`.

Campo	Valor
Severidad	[ALTA] Media · Prioridad **P1** — atendida
Impacto	Gobierna el ciclo de vida de todo incidente: conservación de `createdAt`, supervivencia de `acknowledged`, resolución automática y reapertura. Una regresión aquí es silenciosa
Evidencia	Ningún archivo de `test/` la ejercita directamente
Recomendación	Es la prueba de mayor valor que falta hoy. Detalle en `12-testing-and-quality.md`
Corrección aplicada	`mergeIncidents` se exporta —es lógica pura, exportarla no amplía superficie— y se cubren aparición, conservación de `createdAt`, supervivencia de `acknowledged`, resolución automática, no re-resolución, reapertura, orden por `lastSeenAt`, ausencia de mutación y refresco de contenido con historial intacto

R-10 · La cola de escritura no tiene prueba de concurrencia

Campo	Valor
Severidad	[ALTA] Media · Prioridad P2
Impacto	`mutate()` es la única defensa contra la pérdida de escrituras concurrentes, y nada verifica que funcione
Evidencia	`test/` no contiene ninguna prueba de dos mutaciones simultáneas
Recomendación	Dos `addWallet` en paralelo sobre un `MemoryStore` deben producir dos wallets

R-11 · Concurrencia entre procesos no soportada

Campo	Valor
Severidad	[ALTA] Media · Prioridad P3
Impacto	Dos instancias con el mismo `DATA_DIR` se pisan: el último `rename` gana y el otro estado se pierde
Evidencia	No hay bloqueo de archivo ni de proceso
Recomendación	Un archivo de bloqueo con el PID, o al menos un aviso al arrancar si detecta otro proceso escuchando

R-12 · `riskScore` y `loadConfig` sin prueba directa

Campo	Valor
Severidad	[ALTA] Media · Prioridad P2
Impacto	`riskScore` es lo que el usuario ve en el panel; `loadConfig` gobierna todo el comportamiento. Ambos solo se cubren de forma indirecta
Recomendación	Fronteras de nivel (0, 35, 65, 85, 100) y comportamiento de recorte de rangos

R-13 · Los artefactos publicados no van firmados

Campo	Valor
Severidad	[ALTA] Media · Prioridad P2
Impacto	Los checksums protegen contra corrupción en tránsito, no contra un repositorio o una cuenta comprometidos
Evidencia	`release-windows.yml` genera `SHA256SUMS.txt`; no hay firma GPG ni certificado
Recomendación	Firmar `SHA256SUMS.txt`, o adoptar atestaciones de procedencia. **Encaja especialmente bien en un producto cuyo argumento es la procedencia verificable**

---

5 · Hallazgos de severidad baja

R-14 · Las caídas silenciosas de configuración

Campo	Valor
Severidad	[ATENCION] Baja · Prioridad P3
Impacto	`PORT=ochenta` arranca en 8787 y `RATE_LIMIT_PER_MINUTE=5` aplica 10, **sin avisar**
Evidencia	`parseInteger` y `parseBoolean` en `src/config.js`
Recomendación	Un aviso en el log cuando un valor se recorta o se descarta. El comportamiento tolerante es correcto; el silencio no

R-15 · `.env.example` sugiere una carga de `.env` que no existe

Campo	Valor
Severidad	[ATENCION] Baja · Prioridad P3
Impacto	Confusión razonable: se crea el `.env`, no pasa nada, y no hay mensaje que lo explique
Evidencia	No hay ninguna carga de `.env` en el código
Recomendación	Un comentario en la primera línea del archivo: *«plantilla; el sistema no lee `.env`, exporta estas variables»*

R-16 · El mapa del limitador de tasa nunca se purga

Campo	Valor
Severidad	[ATENCION] Baja · Prioridad P3
Impacto	Una entrada por dirección vista, sin cota
Evidencia	`createRateLimiter` en `src/app.js`
Mitigación	En el despliegue soportado el mapa tiene una entrada
Recomendación	Purgar las ventanas vencidas cada N peticiones

R-17 · Efecto de borde del limitador de ventana fija

Campo	Valor
Severidad	[ATENCION] Baja · Prioridad P4
Impacto	Se pueden hacer hasta el doble del límite a caballo de dos ventanas
Recomendación	Ventana deslizante, si alguna vez importara. Hoy no importa

R-18 · `x-request-id` no se registra en el log

Campo	Valor
Severidad	[ATENCION] Baja · Prioridad P3
Impacto	Se emite en cada respuesta pero no aparece en el log del 5xx: no se pueden correlacionar

Campo	Valor
Recomendación	Añadirlo al objeto JSON de `request_failed`. Una línea

R-19 · Sin `fsync` explícito tras escribir

Campo	Valor
Severidad	[ATENCION] Baja · Prioridad P4
Impacto	Un corte de corriente inmediatamente después de `rename` podría perder la última escritura
Mitigación	El `rename` garantiza que nunca queda un estado a medias
Recomendación	Aceptable. Registrado para que la decisión sea explícita

R-20 · Imagen base Docker por etiqueta, no por digest

Campo	Valor
Severidad	[ATENCION] Baja · Prioridad P3
Impacto	`node:24-alpine` puede cambiar bajo la misma etiqueta
Evidencia	Primera línea del `Dockerfile`
Recomendación	Fijar por digest, **coherente con el rigor que ya se aplica a las actions de GitHub**

R-21 · `zizmor` y `hadolint` pinneados por versión, no por hash

Campo	Valor
Severidad	[ATENCION] Baja · Prioridad P3
Impacto	Se descargan por número de versión; `gitleaks` sí se verifica por checksum
Recomendación	Aplicarles el mismo criterio que a `gitleaks`

---

6 · Escalabilidad

R-22 · Todo el estado se carga y se reescribe en cada operación

Campo	Valor
Severidad	[ALTA] Media · Prioridad P4
Impacto	Con miles de eventos, cada mutación cifra y escribe el archivo completo
Probabilidad	Baja en uso doméstico; **cierta si el watchtower corre meses con un nodo activo**
Recomendación	Aceptable para el alcance actual. Si se abordara, la respuesta natural sería un registro de solo anexado, no un SGBD

R-23 · Búsqueda de aprobación cuadrática

Campo	Valor
Severidad	[ATENCION] Baja · Prioridad P4
Impacto	`approvals.some(...)` dentro del bucle de gastos es O(n·m)
Recomendación	Un `Set` de hashes construido una vez por evaluación. **Cuesta dos líneas**

R-24 · Nada se borra nunca

Campo	Valor
Severidad	[NO COMPROBADO] Observación · Prioridad P4
Impacto	Wallets, incidentes, eventos y auditoría solo crecen. No hay endpoint de borrado
Valoración	**Correcto para un producto de respuesta a incidentes**: el historial es evidencia. Se registra porque implica que el archivo crece de forma monótona y que un error de registro no se puede corregir

---

7 · Observaciones

R-25 · `build/portable/` duplica el árbol de `src/`

Campo	Valor
Severidad	[NO COMPROBADO] Observación
Hecho	`build/portable/RootCause-Bitcoin-Defense/` contiene una copia completa de `src/`, `scripts/`, `config/` y `docs/`
Valoración	**No es código duplicado**: es el paquete ensamblado, está en `.gitignore` y se regenera en cada empaquetado
Riesgo residual	Alguien que busque con `grep` en todo el árbol encontrará dos copias de cada símbolo y podría editar la equivocada
Recomendación	Ninguna. Registrado para quien navegue el repositorio por primera vez

Otras observaciones

#	Observación	Valoración
1	El panel solo permite single-sig y multisig 2-de-3	Limitación de la interfaz, no del sistema. **`BTC-CUSTODY-003` no se puede provocar desde el panel**, solo por API
2	El panel llama a `POST /api/scan` tras registrar una wallet, aunque `addWallet` ya reevalúa	Redundante; el efecto es una entrada de auditoría extra
3	`pnpm-workspace.yaml` está vacío pero es obligatorio para `validate-repo.js`	Sin él, el build cae. Curioso, no problemático
4	601 líneas de JavaScript de navegador sin ninguna prueba	Coherente con la ausencia de herramientas de test de DOM sin dependencias

---

8 · Lo que este análisis no pudo evaluar

#	Elemento	Por qué
1	Los avisos contra la fuente oficial del fabricante	Requiere red y criterio humano
2	El instalador Inno Setup	`ISCC.exe` no disponible en el entorno
3	La conexión real con Bitcoin Core	No hay nodo en el entorno
4	Los workflows en ejecución	Se leyeron; no se dispararon
5	El artefacto publicado en Releases	Fuera del árbol de trabajo
6	CodeQL, `gitleaks`, `zizmor`, `hadolint`	Corren en GitHub

Ninguna de estas seis líneas es un aprobado. Son superficies que este análisis no miró, y decirlo es la única forma honesta de presentar el resto.

---

9 · Decisiones que requieren validación humana

#	Decisión	Quién debe decidir
1	¿`expiresAt` debe caducar de verdad, o retirarse del modelo?	Mantenedor
2	¿Los campos declarativos de `policies.json` se aplican o se marcan como tales?	Mantenedor
3	¿Se firman los artefactos publicados?	Mantenedor
4	¿El umbral de alto valor por defecto (0,1 BTC) es el adecuado?	Depende de la política de cada operador
5	¿La ventana de ráfaga de una hora es la correcta?	Requiere datos de incidentes reales
6	¿30 días es el plazo adecuado de frescura de la inteligencia?	Depende del ritmo de avisos del sector

---

Siguiente	
Glosario	`16-glossary.md`
Resumen ejecutivo	`17-executive-summary.md`
Volver al índice	`README.md`